ENTERPRISE ARCHITECTURE SPECIFICATION • RELEASE 2.2

Staff Management Portal - Technical Specification

Comprehensive engineering reference covering dual-gateway multi-login authentication (Email/Password & Google OAuth 2.0 / OpenID Connect), multi-tenant company workspace isolation, RESTful microservices, and live cloud production deployment.

Author / Lead Engineer:	Sudhir Kumar	**GitHub Repository:**	github.com/sudhirkr2003/staff-management-portal
Production Frontend:	**https://staff-btv0.onrender.com**	**Production Backend API:**	**https://staff-backend-mwuh.onrender.com**
Interactive Swagger UI:	https://staff-backend-mwuh.onrender.com/swagger-ui/index.html	**OpenAPI 3.0 JSON Schema:**	https://staff-backend-mwuh.onrender.com/v3/api-docs
Live Health Endpoint:	https://staff-backend-mwuh.onrender.com/api/health (200 OK)	**Managed Cloud Database:**	Aiven MySQL (defaultdb, SSL REQUIRED)
Deployment Branches:	main (Production), develop (Active Dev)	**Preserved Feature Branch:**	main-otp (Dedicated Email OTP Flow)
Core Technologies:	Java 17, Spring Boot 3.3.5, React 18 (Vite 5), MySQL 8.0	**Document Publication:**	05 November 2026 • Version 2.2.0

1. System Architecture & Tier Breakdown

The platform is engineered as an enterprise-grade multi-tenant workforce management solution. It isolates administrative workspaces, provides comprehensive employee CRUD operations, calculates real-time departmental headcount and payroll statistics, and protects all administrative operations behind high-security stateless authentication tokens.

Architectural Tier	Technology Stack	Core Responsibilities & Capabilities
Presentation Tier (SPA)	React 18, Vite 5, Axios, Lucide React, HTML5/CSS3	Responsive web interface, automated 2-second onboarding transition, client-side input validation, dynamic Swagger UI routing, and unified error/success state alerts.
Application Tier (REST)	Java 17, Spring Boot 3.3.5, Spring Security 6, Hibernate	Stateless REST API services, OAuth2 OpenID client, JWT filter pipeline, transaction management, BCrypt encryption, and company isolation enforcement.
Documentation Tier	SpringDoc OpenAPI 3.0, Swagger UI 2.6.0	Live interactive API testing sandbox, auto-generated OpenAPI schemas, Bearer JWT authentication authorization header injection.
Cloud Persistence Tier	Aiven MySQL 8.0 Cloud Cluster	Fully managed relational database with SSL enforcement (sslMode=REQUIRED), HikariCP high-throughput connection pooling, and automated schema migrations.
Hosting & Edge Delivery	Render Cloud PaaS & Static Web Platform	Multi-stage Dockerized backend service with HTTPS edge termination, continuous GitHub integration, zero-downtime rolling deploys, and automated health checks.

Branch Deployment Architecture & Release Strategy:
• **main (Production):** Active production branch deployed to Render. Configured for direct admin registration, immediate auto-login, automated 2-second workspace setup transition, and direct password reset.
• **develop (Staging / Dev):** Active development branch continuously synchronized with main.
• **main-otp (Dedicated Feature Preservation):** Dedicated branch maintaining the complete email OTP verification workflow for registration and password recovery.

2. Multi-Login Architecture & Dual-Gateway Security

A central innovation of the Staff Management Portal is its **Dual-Gateway Multi-Login Architecture**. Enterprise administrators require flexible, enterprise-grade access methods that accommodate both standard corporate credentials and modern federated identity providers (Google OAuth 2.0 / OpenID Connect). Both authentication pathways converge seamlessly into a unified, cryptographically signed JSON Web Token (JWT) session.

Authentication Pathway Comparison Matrix

Feature / Capability	Method 1: Standard Credentials	Method 2: Google OAuth 2.0 / OpenID Connect
Identity Provider	Local MySQL User Directory (Internal)	Google Identity Services (Federated OpenID)
Protocol / Standard	RESTful JSON POST with BCrypt Hashing	OAuth 2.0 Authorization Code Flow + OpenID Connect
Required Form Input	Email address and strong account password	Single click on 'Continue with Google' button
Password Security	Salted BCrypt hashing with work factor 10	Google-managed credentials (no password stored locally)
Session Result	Standard Bearer JWT with ADMIN role claim	Identical Bearer JWT with ADMIN role claim
Unlinked Account Handling	Account registration form with validation	Guided password prompt: *'Your Google account is not registered. Create a password to complete your registration.'*
Auto-Login Support	Instant token issuance upon registration	Instant token issuance if Google profile exists

Stateless JSON Web Token (JWT) Security Specifications

Both authentication channels yield an identical, high-entropy JWT token generated via HMAC-SHA256 (HS256). The token architecture guarantees zero server-side session memory consumption while preserving tamper-proof cryptographic verification on every request.

- **Algorithm & Signature:** HMAC using SHA-256 with a 256-bit cryptographically secure secret (JWT_SECRET).
- **Token Expiration:** 24 hours (86,400,000 milliseconds) from issuance timestamp.
- **Claims Payload:** Includes id (database user ID), sub (normalized user email), and role (ADMIN).
- **Client Storage & Injection:** Tokens are preserved in browser localStorage and automatically appended by Axios interceptors to all outbound requests: Authorization: Bearer <token>.
- **Security Interceptor:** JwtAuthenticationFilter parses and verifies the token on incoming requests. Invalid or expired tokens trigger an HTTP 401 Unauthorized response, causing the client to clear stored credentials and transition to the login portal.

Enterprise Password Policy & Cryptographic Hashing

For administrators utilizing standard credentials, password complexity is rigorously verified both on client submission and by the backend authentication service. Passwords must be at least 8 characters long and contain at least one uppercase letter, one lowercase letter, one numeric digit, and one special symbol (@$!%*?&#). Upon verification, passwords are encrypted using Spring Security's BCryptPasswordEncoder with salt generation and 10 hashing rounds before persistence.

3. Deep-Dive: Google OAuth 2.0 & OpenID Connect Flow

The Google federated authentication flow provides single-click access for enterprise administrators while adhering to modern OpenID Connect identity standards. This section provides an exhaustive walkthrough of the handshake, account linking, and unlinked account resolution.

End-to-End Google OAuth 2.0 Sequence

Step	Actor / Component	Protocol / Endpoint	Action & Payload Description
1	Administrator	Client UI Button	Clicks 'Continue with Google' on Login or Register page.
2	Frontend Client	/oauth2/authorization/google	Redirects browser to Spring Security OAuth2 authorization endpoint.
3	Spring Security	accounts.google.com/o/oauth2/v2/auth	Redirects user to Google OAuth 2.0 consent screen with client_id, scope=openid email profile.
4	Google Auth Server	User Consent Screen	User authenticates with Google and grants permission to share profile details.
5	Google Auth Server	/login/oauth2/code/google	Redirects back to backend callback endpoint with one-time authorization code.
6	Backend OAuth Client	oauth2.googleapis.com/token	Exchanges authorization code for Google ID token and access token securely server-side.
7	OAuth2 Success Handler	OAuth2AuthenticationSuccessHandler	Extracts Google claims: sub (Google ID), email, email_verified, and name.

Account Resolution & Dynamic Linking Engine

When Google returns verified claims to OAuth2AuthenticationSuccessHandler, the system evaluates the user database across three distinct resolution pathways:

- **Scenario A - Existing Registered User by Email:** If an account with the matching email already exists, the handler automatically links the user's googleId, sets the provider to BOTH, ensures the role is ADMIN, generates a production JWT session token, and redirects to https://staff-btv0.onrender.com/?status=login_success&token=....
- **Scenario B - Existing User by Google ID:** If the user previously logged in via Google, the handler generates a fresh JWT token and redirects immediately to the authenticated application.
- **Scenario C - Unregistered / First-Time Google User:** If neither email nor Google ID is recognized, the portal will **not** arbitrarily auto-create incomplete accounts. Instead, it generates a signed, tamper-evident regToken containing the user's Google ID, email, and name, redirecting the browser with status=google_register&regToken=....

CRITICAL USER EXPERIENCE - UNREGISTERED GOOGLE NOTIFICATION:
When an unregistered Google account is detected, the login view transitions into Registration Completion mode with the prominent red warning:
"Your Google account is not registered. Create a password to complete your registration."
The administrator is presented with a pre-filled email and prompted to establish a secure password. Upon submission to /api/auth/google/complete-registration, the account is fully provisioned with provider BOTH and immediately logged in.

4. User Lifecycle, Admin Registration & Onboarding Workflows

The user onboarding workflow has been streamlined to minimize friction while enforcing data integrity and security. Below are the core state transitions from initial account creation to corporate workspace provisioning.

Direct Administrator Registration Flow

In the current production release, administrator registration operates with immediate database provisioning and automatic authentication:

- **Form Submission:** The user submits full name, corporate email address, and matching passwords on /register.
- **Backend Verification:** The service verifies email uniqueness, validates password strength, hashes credentials via BCrypt, and inserts the user record with role ADMIN.
- **Auto-Login Token Generation:** Instead of halting the user, AdminAuthService immediately generates a valid JWT token and returns it within a LoginResponse object.

Automated 2-Second Green Tick Success Transition

To eliminate manual navigation steps, the registration screen displays an immediate confirmation and automatically routes the admin to organization setup:

AUTOMATED ONBOARDING TRANSITION (2-SECOND TIMER):
1. Upon receiving HTTP 200 from /api/auth/admin/register, the UI renders the **Registration Successful** screen with a green checkmark icon.
2. The client records the returned JWT token into application state and localStorage.
3. An active setTimeout interval counts down 2,000 milliseconds (2 seconds).
4. The screen smoothly disappears and automatically opens the **Company Workspace Setup Modal** (/company/create) without requiring the user to navigate manually or re-authenticate.

Direct Password Recovery & Reset Flow

To ensure administrators are never locked out due to third-party mail relay limitations, the password reset flow supports direct self-service credential recovery:

- **Recovery Gateway:** Administrators click 'Forgot Password?' on the login screen. They may authenticate via Google OAuth or reset their password directly.
- **Direct Password Reset:** The administrator provides their registered email and specifies a new, compliant password with confirmation.
- **Atomic Update:** The backend re-hashes the new password with BCrypt, updates the user credentials in MySQL, and transitions back to login with a success alert.

First-Time Administrator Journey Stages

Stage	User Action	System Operation	Outcome / Next State
1. Register	Enters credentials on /register	BCrypt hash + DB persist + JWT generated	JWT saved, shows Green Tick screen
2. Transition	Watches success confirmation	2-second auto-timer runs in background	Automatically transitions to Setup
3. Workspace	Enters Company Name, Industry, Phone	POST /api/companies bound to admin ID	Company workspace initialized
4. Management	Adds employees, assigns departments	POST /api/employees with company scope	Live dashboard and analytics active

5. Multi-Tenant Workspace & Workforce Management Engine

The platform enforces multi-tenant workspace boundaries. Every company entity is strictly bound to its creating administrator, and all employee records, departments, and payroll totals are compartmentalized within that organization.

Tenant Workspace Isolation Architecture

- **Relational Scoping:** The Company entity holds a foreign key to the User administrator. The Employee entity contains a mandatory foreign key reference to Company.
- **Service-Level Protection:** API operations query EmployeeRepository.findByCompany(company), ensuring an administrator from Organization A cannot view, modify, or delete employee data from Organization B.
- **Workspace State Management:** The frontend company settings modal prevents form resets during input by guarding state against background re-render cycles.

Employee Lifecycle Management (CRUD)

Operation	Endpoint Path	Payload / Parameters	Business Validation & Security Rules
Create Employee	`POST /api/employees`	Name, Email, Department, Designation, Salary	Validates email syntax, ensures unique email per company, positive salary, valid department.
List Employees	`GET /api/employees`	Bearer JWT Header	Returns all active employees scoped strictly to the authenticated administrator's company.
Update Employee	`PUT /api/employees/{id}`	Updated employee profile object	Verifies employee belongs to caller company before applying modifications.
Delete Employee	`DELETE /api/employees/{id}`	Target Employee ID path variable	Executes atomic record deletion with UI confirmation dialog.

Real-Time Department Distribution Analytics

The platform incorporates an analytics engine accessible via GET /api/employees/departments. This service executes optimized SQL aggregation queries (GROUP BY department) to return live workforce breakdown metrics: headcount per department, active percentage distribution, and total aggregated annual payroll expenditure. The frontend visualizes these figures in dynamic summary cards on the admin dashboard.

Dynamic Environment-Aware Swagger UI Integration

To ensure seamless navigation between development and live cloud environments, the client application dynamically binds the Swagger UI documentation link using import.meta.env.VITE_API_BASE_URL:

DYNAMIC SWAGGER UI RESOLUTION LOGIC:
- **Local Environment:** When running locally, the top navigation 'Swagger UI' link resolves dynamically to http://localhost:8080/swagger-ui/index.html.
- **Production Environment:** On Render (https://staff-btv0.onrender.com), the link resolves automatically to https://staff-backend-mwuh.onrender.com/swagger-ui/index.html.
- **Zero Hardcoding:** Prevents broken localhost redirects after cloud deployment, providing administrators with instant access to the OpenAPI live testing sandbox.

6. REST API Specifications, Cloud Hosting & Telemetry

This section documents the public and authenticated REST endpoints, cloud containerization parameters, and continuous uptime monitoring configurations.

Comprehensive REST API Endpoint Catalog

HTTP	Endpoint Path	Auth	Description & Response Codes
GET	`/api/health`	Public	Health probe returning service status UP and timestamp (200 OK)
GET	`/swagger-ui/index.html`	Public	Interactive OpenAPI 3.0 documentation & live API test console
GET	`/v3/api-docs`	Public	Raw OpenAPI 3.0 JSON schema for automated integrations
POST	`/api/auth/admin/register`	Public	Direct admin registration; returns JWT session token (201 Created)
POST	`/api/auth/login`	Public	Standard credentials authentication; returns Bearer JWT (200 OK)
POST	`/api/auth/google/complete-registration`	Public	Completes Google account registration with password; returns JWT (200 OK)
POST	`/api/auth/reset-password`	Public	Direct password reset with email and password validation (200 OK)
GET	`/api/auth/profile`	Admin	Fetches authenticated administrator profile details (200 OK / 401)
GET	`/api/companies/my-company`	Admin	Retrieves corporate company profile for current admin (200 OK)
POST	`/api/companies`	Admin	Creates new corporate workspace bound to admin (201 Created)
PUT	`/api/companies`	Admin	Updates organization profile (industry, contact phone, website)
GET	`/api/employees`	Admin	Lists all employees in administrator's isolated workspace (200 OK)
POST	`/api/employees`	Admin	Creates new employee record with salary and department (201 Created)
DELETE	`/api/employees/{id}`	Admin	Permanently deletes specified employee record (200 OK)
GET	`/api/employees/departments`	Admin	Calculates department headcount and payroll analytics (200 OK)

Production Cloud Hosting & Uptime Telemetry

• **Backend Web Service (Render):** Multi-stage Docker container built from eclipse-temurin:17-jre-jammy. Inbound traffic terminates via TLS/HTTPS on port 443 with internal proxy routing to port 8080.

• **Cloud Database (Aiven MySQL):** Managed MySQL 8.0 cluster with mandatory SSL encryption (sslMode=REQUIRED) and HikariCP connection pooling configured with auto-reconnect.

• **Automated Uptime Keep-Alive:** Uptime monitoring configured against https://staff-backend-mwuh.onrender.com/api/health with a 5-minute HTTP poll frequency to ensure constant backend container readiness.